

בנק שאלות תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1.  בנק שאלות תרגול (Practice Question Bank)

בנק שאלות תרגול (Practice Question Bank)

שאלות תרגול לכל הקורס — ידע (Knowledge) ותרחישים מעשיים (Scenario). **מפתח התשובות בסוף המסמך.** נסה לענות לבד לפני שתציץ.

השאלות מסודרות לפי מודול. סוגי שאלות: **בחירה** (רב-ברירה), **פתוחה** (תשובה קצרה), **תרחיש** (מה תעשה בסיטואציה).

מודול 1 — מבוא ומתודולוגיה

Q1 (בחירה) מהו הסדר הנכון של חמשת שלבי ההאקিং האתי? (א - Scanning → Recon → Exploitation → Maintaining Access → Covering Tracks) (ב - Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks) (ג - Recon → Exploitation → Scanning → Maintaining Access → Covering Tracks) (ד - Scanning → Gaining Access → Recon → Covering Tracks → Maintaining Access)

Q2 (פתוחה) מהם שלושת עקרונות ה-CIA Triad?

Q3 (בחירה) בדיקה שבה נותנים לבודק רק שם דומיין, ללא שום מידע נוסף, נקראת: (א - White Box) (ב - Grey Box) (ג - Black Box) (ד - Crystal Box)

Q4 (תרחיש) קיבלת בדיקת חדירות. תוך כדי עבודה גילית שרת פגיע שאינו מופיע ב-Scope. מה מותר ומה אסור לך לעשות?

Q5 (פתוחה) הסבר את ההבדל בין Vulnerability, Exploit ו-Payload.

מודול 2 — יסודות Linux

Q6 (בחירה) איזו פקודה מציגה את כל קובצי ה-SUID במערכת? (א - `find / -type suid`) (ב - `find / -perm -4000 2>/dev/null | xargs ls -l`) (ג - `ls -l | grep suid`) (ד - `find / -perm -4000`)

Q7 (פתוחה) מה ההבדל בין `>` ל-`>>` בהפניית פלט?

Q8 (בחירה) שורת ההרשאות `-rwxr-x---` שווה לאיזה ערך Octal? (א - 755) (ב - 750) (ג - 640) (ד - 770)

Q9 (תרחיש) השגת גישה למכונת Linux כמשתמש רגיל. מהי אחת הפקודות הראשונות שתריץ כדי לבדוק אפשרות הסלמת הרשאות, ולמה?

Q10 (פתוחה) אילו שני קבצים ב- `/etc` הם היעדים החמים ביותר להאקר, ומה כל אחד מכיל?

מודול 3 — יסודות רשתות

Q11 (בחירה) לחיצת היד של TCP מורכבת מ: א - $\text{ACK} \rightarrow \text{SYN}$ (ב - $\text{ACK} \rightarrow \text{SYN-ACK}$ (ג - $\text{ACK} \rightarrow \text{SYN} \rightarrow \text{FIN}$ (ד - $\text{ACK} \rightarrow \text{SYN} \rightarrow \text{RST}$

Q12 (פתוחה) לאיזה שירות שייך כל פורט: 22, 80, 443, 445, 3389?

Q13 (בחירה) בסריקת nmap, איזו תשובת שרת ל-SYN מעידה שהפורט סגור? - א - $\text{ACK} \rightarrow \text{SYN-ACK}$ (ב - ACK (ג - RST (ד - אין תשובה

Q14 (תרחיש) אתה מקבל את הכתובת 10.0.5.23. האם היא פרטית או ציבורית? לפי איזה טווח?

Q15 (פתוחה) כמה כתובות יש בתת-רשת 24/2? כמה מהן שמישות למארחים?

מודול 4 — סקריפטינג

Q16 (בחירה) בשם Payload, מה מסמן ה- `/reverse_tcp(...)` (למשל `Non-Staged` (ב - `Staged` (ג - `Bind` (ד - `Encrypted`

Q17 (פתוחה) מה מחזירה הפונקציה `connect_ex` ב-Python כשהפורט פתוח?

Q18 (תרחיש) נתון `banner = "Apache/2.4.49"`. כתוב שורת Python אחת שמחלצת רק את 2.4.49.

Q19 (בחירה) איזה מבנה נתונים ב-Python אינו ניתן לשינוי? - א - `List` (ב - `Dictionary` (ג - `Tuple` (ד - `Set`

מודול 5 — איסוף מידע

Q20 (בחירה) גילוי תת-דומיינים באמצעות Sublist3r הוא סוג של איסוף: - א - אקטיבי (ב - פסיבי (ג - פיזי (ד - הסלמה

Q21 (פתוחה) מהי מטרת ה-OSINT על מיילים, ואיזה כלי משמש לזיהוי תבנית המייל של ארגון?

Q22 (תרחיש) אתה רוצה למצוא קובצי PDF חשופים בדומיין target.com. כתוב את שאילתת Google Dorking.

Q23 (בחירה) Burp Suite פועל בעיקר כ: - א) סורק פורטים · ב) Proxy בין דפדפן לשרת · ג) מפצח סיסמאות · ד) סורק חולשות

מודול 6 — סריקה ומיפוי

Q24 (בחירה) איזו פקודת nmap סורקת את כל 65,535 הפורטים? - א) `nmap -F` · ב) `nmap -p` · ג) `nmap -sn` · ד) `nmap -top`

Q25 (פתוחה) מה עושה הדגל `-sV` ב-nmap, ולמה הוא חשוב לחקר חולשות?

Q26 (תרחיש) nmap הראה פורט 445 פתוח עם Samba. אילו שתי פקודות תריץ כדי למנות אותו לעומק?

Q27 (בחירה) איזה כלי מבצע Directory Brute-Force על שרת web? - א) `enum4linux` · ב) `gobuster` · ג) `searchsploit` · ד) `hydra`

Q28 (פתוחה) מהו הגשר בין "מצאתי גרסת שירות" ל-"יש לי Exploit"? איזה כלי Kali משמש לכך?

מודול 7 — ניצול

Q29 (בחירה) באיזה סוג Shell **הקורבן** יוזם את החיבור אל התוקף? - א) Bind Shell · ב) Reverse Shell · ג) Web Shell · ד) Root Shell

Q30 (פתוחה) מדוע Reverse Shell עוקף חומות אש טוב יותר מ-Bind Shell?

Q31 (תרחיש) ב-Metasploit בחרת Exploit. איזה שלושה פרמטרים חובה תגדיר לפני `exploit`, ומה כל אחד?

Q32 (בחירה) איזה כלי יוצר Payload עצמאי (למשל קובץ exe להעלאה ליעד)? - א) `msfconsole` · ב) `msfvenom` · ג) `searchsploit` · ד) `nmap`

Q33 (תרחיש) קיבלת Shell אך הוא לא יציב ונופל. מה שתי הפעולות שתנסה?

🎯 שאלות אינטגרציה — בסיס (מודולים 1-7)

Q34 (תרחיש מלא) קיבלת IP יחיד: 192.168.56.101. תאר את שרשרת הפעולות המלאה שתבצע — צעד אחר צעד — מ-"כלום" ועד "root", תוך ציון הכלי בכל שלב.

Q35 (תרחיש) nmap הראה: `80/tcp open http Apache 2.4.49`. מה כל הצעדים הבאים שלך עד לניסיון ניצול?

Q36 (פתוחה) מדוע אומרים ש-"90% מהעבודה היא Enumeration"? הסבר בהקשר של שרשרת התקיפה.

מודול 8 — מתקפות סיסמאות

Q37 (בחירה) מה ההבדל בין Online ל-Offline password attack? (א - Online מהיר יותר · ב) Offline תוקף Hash שנלכד, ללא אינטראקציה עם השירות (ג - Online לא רועש · ד) אין הבדל

Q38 (פתוחה) מהו ה-wordlist הנפוץ ביותר ב-Kali, והיכן הוא נמצא?

Q39 (בחירה) איזה כלי מתאים ל-Brute-Force **מקוון** מול שירות SSH/RDP/HTTP? (א - hashcat · ב) john · ג) hydra · ד) searchsploit

Q40 (תרחיש) לכדת Hash מסוג NTLMv2. באיזה כלי ובאיזה mode תפצח אותו? למה Offline עדיף כאן?

מודול 9 — אבטחת Web (OWASP Top 10)

Q41 (בחירה) ה-payload `-- ' OR '1'='1' --` בטופס התחברות הוא דוגמה ל: (א - XSS · ב) SQL Injection · ג) CSRF · ד) SSRF

Q42 (פתוחה) מהי IDOR, ואיזו קטגוריית OWASP היא (A0X)?

Q43 (בחירה) קלט `127.0.0.1; whoami` בדף ping שקול לחולשת: (א - LFI · ב) XSS · ג) Command Injection (RCE) · ד) SSRF

Q44 (תרחיש) מצאת שדה קלט שמחזיר `<script>alert(1)</script>` שרץ בדפדפן. איך תקבע אם זה Stored או Reflected, ואיזה מהם חמור יותר?

מודול 10 — Buffer Overflow

Q45 (בחירה) באיזה רגיסטר התוקף שואף לשלוט כדי להכתיב את זרימת הריצה? (א - ESP · ב) EBP · ג) EIP · ד) EAX

Q46 (פתוחה) מהם שבעת שלבי מתודולוגיית ה-BOF לפי הסדר?

Q47 (תרחיש) מצאת שכתובת ה- JMP ESP היא 625011AF. כיצד תכתוב אותה ב-payload, ולמה?

מודול 11 — פוסט-אקספלויטציה והסלמת הרשאות

Q48 (בחירה) איזו פקודה מציגה אילו תוכניות מותר להריץ כ-sudo? (א - sudo -v (ב - sudo -l (ג - sudo su (ד - id

Q49 (פתוחה) מהו GTFOBins, ואיך הוא עוזר בהסלמת הרשאות ב-Linux?

Q50 (בחירה) ב-Windows, איזו הרשאה מובילה למתקפות "Potato" ל-SYSTEM? (א - SeDebugPrivilege (ב - SeImpersonatePrivilege (ג - SeBackupPrivilege (ד - SeShutdownPrivilege

Q51 (תרחיש) קיבלת Shell כ-www-data. מהם שני הצעדים הראשונים שתעשה לפני ניסיון הסלמה, ומדוע?

מודול 12 — Pivoting ותנועה רוחבית

Q52 (בחירה) איזה דגל SSH יוצר SOCKS proxy דינמי מלא? (א -L (ב -R (ג -D (ד -N

Q53 (פתוחה) למה חובה -sT ו-Pn כשמריצים nmap דרך proxychains?

Q54 (תרחיש) פרצת מכונה עם שני ממשקי רשת (eth0 = 10.10.10.0/24, eth1 = DMZ פנימי). כיצד תגיע ממכונת Kali שלך לשרת 10.10.10.30 שאינו נגיש ישירות?

מודול 13 — Active Directory

Q55 (בחירה) מתקפת Responder מנצלת אילו פרוטוקולים כדי ללכוד NTLMv2 hash? (א - DNS/DHCP (ב - LLMNR/NBT-NS (ג - SMB/RDP (ד - HTTP/HTTPS

Q56 (פתוחה) מהו Kerberoasting, ולמה כל משתמש דומיין יכול לבצע אותו?

Q57 (בחירה) מהו mode של hashcat לפיצוח TGS (Kerberoast)? (א - 5600 (ב - 13100 (ג - 18200 (ד - 22000

Q58 (פתוחה) מה עושה BloodHound, ואיזו שאילתה מרכזית מחפשים בו?

Q59 (תרחיש) השגת NTLM hash של Local Admin המשותף בין מכונות. איך תשתמש בו לתנועה רוחבית מבלי לפצח אותו? איך נקראת הטכניקה?

מודול 14 — תקיפות אלחוטיות

Q60 (בחירה) מהו הפרוטוקול האלחוטי ה"שבור" שנפצח תוך דקות ללא קשר לסיסמה? (א - WPA2 · ב) WPA3 · ג) WEP · ד) WPA-Enterprise

Q61 (פתוחה) מהו 4-Way Handshake, ולמה משתמשים ב-Deauth כדי ללכוד אותו?

Q62 (תרחיש) מתקפת Evil Twin מצליחה גם מול WPA2 עם סיסמה חזקה. הסבר מדוע — מה בעצם היא תוקפת?

מודול 15 — הנדסה חברתית ופשינג

Q63 (בחירה) פשינג ממוקד לאדם ספציפי, מותאם אישית, נקרא: (א - Phishing · ב) Spear Phishing · ג) Baiting · ד) Vishing

Q64 (פתוחה) אילו שני עקרונות השפעה משולבים ברוב מיילי הפשינג המוצלחים? תן דוגמה.

Q65 (תרחיש) סיימת סימולציית פשינג ו-12% מהעובדים מסרו סיסמה. כיצד תציג זאת בדוח מבלי לפגוע בעובדים?

מודול 16 — כתיבת דוח ותיעוד

Q66 (בחירה) איזה חלק בדוח מיועד להנהלה הלא-טכנית? (א - Findings · ב) Executive Summary · ג) נספח טכני · ד) מתודולוגיה

Q67 (פתוחה) מהם המרכיבים ההכרחיים של ממצא מקצועי בדוח?

Q68 (תרחיש) דרג ב-CVSS: (א) SQLi בדף לקוחות ציבורי; (ב) banner שחושף גרסת שרת. נמק כל דירוג.

🎯 שאלות אינטגרציה — מתקדם (מודולים 8–16)

Q69 (תרחיש מלא) בבדיקה פנימית חוברת לרשת LAN **ללא אישורים**. תאר שרשרת מלאה מ-"כבל רשת" ועד **Domain Admin**, בציון הכלי בכל שלב.

Q70 (תרחיש) פרצת שרת web (www-data), הסלמת ל-root, ומצאת ב-Looting מפתח SSH וסיסמת DB. כיצד תמשיך לרשת הפנימית? אילו מודולים משתלבים כאן?

Q71 (פתוחה) הסבר את הקשר בין מודול 8 (פיצוח סיסמאות) למודול 13 (AD) ולמודול 14 (Wireless) — מה המשותף בעיקרון התקיפה?

Q72 (תרחיש) קמפיין פישיונג הניב סיסמה של עובד. תאר כיצד היא מתגלגלת לגישה פנימית ולתקיפת AD, ואילו **שתי** הגנות היו שוברות את השרשרת.

מפתח תשובות (Answer Key) ✓

Q1 ב. **Q3** Confidentiality, Integrity, Availability. **Q2** ג. (Black Box). **Q4** אסור לתקוף אותו (מחוץ ל-Scope = לא מורשה); מותר ומומלץ לתעד ולדווח ללקוח ולהמליץ להוסיפו ל-Vulnerability **Q5**. Scope=הפגם, Exploit=ניצול הפגם, Payload=הקוד שרץ אחרי.

Q6 ב. **Q7** > דורס/יוצר קובץ; >> מוסיף בסוף מבלי לדרוס. **Q8** ב. (750). **Q9** sudo -l — מציג אילו פקודות מותר להריץ כ-root; הרשאות sudo שגויות = מסלול הסלמה קלאסי. (גם find / -perm -4000 תקין). **Q10** /etc/passwd (רשימת משתמשים, קריא לכולם) ו-/etc/shadow (Hash של הסיסמאות, root בלבד).

Q11 ב. **Q13** 22=SSH, 80=HTTP, 443=HTTPS, 445=SMB, 3389=RDP. **Q12** ג. (RST). **Q14** פרטית — טווח 10.0.0.0/8. **Q15** 256 כתובות, 254 שמישות.

Q16 ב. (Staged). **Q17** 0. (אפס). **Q19** . banner.split("/") [1] **Q18** ג. (Tuple).

Q20 א. (אקטיבי — Sublist3r שולח שאילתות; חלק ממקורותיו פסיביים אך הכלי נחשב לאקטיבי/מעורב). **Q21** לזהות תבנית מייל של הארגון (לפישנינג/Spraying בתוך Scope); הכלי: **Q22** hunter.io. **Q23** site:target.com filetype:pdf ב. (Proxy).

Q24 ב. (-p). **Q25** מזהה גרסאות שירותים; הגרסה מאפשרת חיפוש Exploit ידוע. **Q26** enum4linux -a <ip> ו- //<ip>/ -L smbclient (או nmap smb-scripts). **Q27** ב. (gobuster). **Q28** חקר חולשות; הכלי: searchsploit (מאגר Exploit-DB המקומי).

Q29 ב. (Reverse Shell). **Q30** כי חומות אש מתירות לרוב תעבורה **יוצאת**; ב-Reverse הקורבן יוצר חיבור יוצא אל התוקף. **Q31** RHOSTS (יעד), LHOST (התוקף/Kali), PAYLOAD (הקוד שירוצץ). **Q32** ב. (msfvenom). **Q33** להחליף בין Payload Staged ל-Non-Staged; לייצב Shell עם python pty / upgrade (stty).

Q34 דוגמה: nmap -sn (חי?) → nmap -sC -sV -p- (פורטים/שירותים) → מנייה לפי שירות (nikto/gobuster/enum4linux) → searchsploit (Exploit) → Metasploit/ידני (set) → root. **Q35** whatweb/nikto → gobuster=whoami → (exploit → RHOSTS/LHOST/PAYLOAD חולשת searchsploit Apache 2.4.49 (Path Traversal, CVE-2021-41773) → ניצול. **Q36** כי גילוי יסודי של כל שירות/גרסה/הגדרה קובע אילו Exploits רלוונטיים; דילוג על מנייה = פספוס וקטורי תקיפה והכשלת השלבים הבאים.

Q37 ב. (Offline תוקף Hash שנלכד, ללא נגיעה בשירות → מהיר ושקט). **Q38** rockyou.txt, ב-/usr/share/wordlists/. **Q39** ג. (hydra). hashcat **Q40** במצב -m 5600 Offline עדיף כי אין Rate-

limiting/נעילת חשבון/רעש מול השירות, ואפשר לנסות מיליוני סיסמאות מהר.

Q41 ב (SQL Injection). **Insecure Direct Object Reference Q42** — גישה למשאב של אחר ע"י שינוי מזהה (`?id=1002`); קטגוריה **Q43**. **A01 (Broken Access Control)** ג **Q44** (Command Injection / RCE). אם ה-payload חוזר רק בתגובה המיידית שלך → **Reflected**; אם נשמר בשרת ורץ לכל צופה → **Stored**. **חמור יותר** (פוגע בכל המשתמשים, ללא לינק).

Q45 ג (EIP). **Spiking Q46** → **Fuzzing** → **Offset** → **מציאת EIP** → **שליטה ב-EIP** → **מציאת Bad Characters** → **מציאת x86** — `\xaf\x11\x50\x62` הפוך: **Shellcode** ב-Little-Endian, הזרקת **Q47**. **JMP ESP** → **הזרקת Q47**. מאחסן כתובות בסדר בתים הפוך בזיכרון.

Q48 ב (`sudo -l`). **Q49** מאגר שמסביר איך לנצל בינאריים לגיטימיים (`find`, `vim`, `awk`) לברירה לפקודת מערכת; בשילוב `SUID/sudo` על אותו בינארי → הסלמה ל-**Q50**. **root** ב (`SeImpersonatePrivilege`). **Q51** (1) לייצב את ה-Shell (`python3 pty + stty`) כדי לעבוד בנוחות ולמנוע נפילה; **Enumeration (2)** מקומי (`id`, `sudo -l`, `LinPEAS`) — כי 90% מההסלמה יושבת במידע שנאסף.

Q52 ג (`-D`). **SYN** (`-sS`) **Q53** לא עובר ב-SOCKS proxy → **חובה -sT** (`TCP Connect`); **ICMP ping** לא עובר בפרוקסי → **Pn** כדי ש-nmap לא ידלג על המכונה. **Q54** מקימים מנהרה דרך ה-`ssh -D`. **Pivot:** `proxychains + user@<pivot> 9050, autoroute` ב-Metasploit, או `Chisel`; ואז `proxychains .nmap -sT -Pn 10.10.10.30`.

Q55 ב (LLMNR/NBT-NS). **Q56** בקשת TGS של חשבונות שירות (SPN) ופיצוחם **offline**; **כל** משתמש דומיין יכול לבקש TGS של כל SPN — זו תכונה של Kerberos, לא באג. **Q57** ב (13100). **NTLMv2=5600**, **Q58** (AS-REP=18200, WPA=22000). **Q58** אוסף את יחסי ה-AD ומצייר גרף; השאילתה המרכזית: **Shortest Path to Domain Admins**. **Q59** **Path to Domain Admins** מתחברים עם ה-hash כמות שהוא (`H` - `evil-winrm`, `crackmapexec`). **Pass-the-Hash** (H, `psexec -hashes`) כי NTLM מאמת מול ה-hash; הטכניקה: **Pass-the-Hash**.

Q60 ג (WEP). **Q61** חילופי המפתחות בעת התחברות לקוח ל-Deauth; AP; מנתק לקוח קיים שיתחבר מחדש → מזרז את לכידת ה-Evil Twin. **Q62** Handshake. לא תוקף את ההצפנה אלא מקים AP מזויף ומרמה את המשתמש **למסור** את הסיסמה (הנדסה חברתית) — לכן חזק WPA2 לא רלוונטי.

Q63 ב (Spear Phishing). **Q64 סמכות + דחיפות**; לדוגמה "מחלקת IT: אפס סיסמה תוך 24 שעות אחרת החשבון ייחסם". **Q65** מדווחים **אחוזים בלבד, ללא שמות**; ממסגרים כהזדמנות להדרכה ולא כענישה — המטרה חינוך ושיפור מודעות.

Q66 ב (Executive Summary). **Q67** תיאור, השפעה (Impact), **PoC** (צעדים + צילומים), המלצת תיקון, והפניות (CVE/OWASP/CWE). **Q68** (א) **~9.8 Critical** — נגיש מרחוק, ללא אימות, חשיפת נתונים מלאה; (ב) **~3.1 Low/Info** — מידע בלבד ללא ניצול ישיר.

Q69 דוגמה: responder (LLMNR) → NTLMv2 → hashcat -m 5600 → משתמש דומיין → bloodhound-python; הרשאות; hashcat -m 13100 → (Kerberoast) GetUserSPNs -request Administrator → Domain Admin. **Q70** של DA → secretsdump (PtH) → DCSync → hash-ל- → מזהים רשת פנימית (ip a), מקימים (ssh -D / Chisel), Pivot, ומשתמשים בסיסמת ה-DB ובמפתח ה-SSH שנאספו כדי להיכנס למכונות פנימיות — משתלבים מודול 11 (Looting), (Pivoting) 12 ו-13 (AD). **Q71** בכולם: לוכדים ייצוג מוצפן של סיסמה (Hash / TGS / Handshake) ומפצחים אותו **offline** במילון (hashcat/john) — אותו עיקרון, מקורות שונים. **Q72** הסיסמה עובדת ב-VPN/OWA → דריסת רגל פנימית → **MFA** (חוסם גם עם סיסמה נכונה) **והדרכות מודעות + סינון מייל** (מונע את הפישינג מלכתחילה).

למד מהתשובות, אל תשנן. אם טעית — חזור למודול הרלוונטי.  חזרה למפת הקורס